خطة المحاضرة، لعضو هيئة التدريس

التجزئة وكلمات السر والتحقق من الهوية

الأمن السيبراني، الجامعة، المحاضرة ٣

المدة
٦٠ دقيقة

المواد
جهاز عرض أو سبّورة، شرائح المحاضرة وورقة الحلقة النقاشية من الحزمة، هواتف أو حواسيب فيها «درسي»، للمختبر

أهداف التعلّم

- نذكر خصائص التجزئة.
- نخزّن كلمات السر بطريقة سليمة.
- نختار عاملًا ثانيًا.

النشاط: اكسر جدولًا وهميًا

١. التمهيد (٥ دقائق): اطلب من الطلاب تخمين عدد تجزئات SHA-256 التي يحسبها معالج رسوميات واحد في الثانية، ثم اكشف رتبة الحجم.
٢. الشرح (١٠ دقائق): اعرض أثر الانهيار وخصائص المقاومة الثلاث.
٣. الكسر (٢٥ دقيقة): تجري الفرق هجوم قاموس على جداول سريعة ومملّحة وArgon2id لمستخدمين اصطناعيين.
٤. القرار (١٥ دقيقة): اكتب سياسة من فقرة واحدة للتخزين والتحقق المتعدد للجامعة.
٥. الختام (٥ دقائق): يكتب الطلاب أكثر نقطة غامضة في المحاضرة وسؤالًا واحدًا، واقرأها قبل الأسبوع القادم.

للنقاش

- كم حسابًا سقط في كل جدول؟
- لماذا يهم الملح حتى مع التجزئة البطيئة؟
- أيّ عامل ستشترطه للموظفين؟

بطاقة الخروج

- اكتب سطر التخزين الذي ستستخدمه لكلمة سر واحدة.

جرّبها في محاضرتك القادمة

أعطِ الفرق جدولًا صغيرًا لمستخدمين وهميين مجزّأً بثلاث طرق، فيقيسون زمن هجوم القاموس على كلٍّ منها ويفسّرون الفرق.

ورقة الحلقة النقاشية، للطلاب

التجزئة وكلمات السر والتحقق من الهوية

الأمن السيبراني، الجامعة، المحاضرة ٣

الاسم _____ المجموعة _____ التاريخ _____

١ سجّلت محاضِرة الدخول عبر صفحة مزيّفة تنقل فورًا إلى الموقع الحقيقي كل ما تكتبه أو توافق عليه. أيّ عامل ثانٍ كان سيوقف المهاجم؟

○ إشعار على الهاتف للموافقة على الدخول ○ مفتاح أمان FIDO2 ○ رمز من تطبيق مصادقة

٢ قدّر جهد المهاجم.

يجرّب برنامج كسر 10^9 تجزئة سريعة في الثانية. فإذا كلّف كل تخمين بـ Argon2id أكثر بـ 10^6 مرة، فلن ينجز إلا _____ تخمين في الثانية. ويستغرق قاموس من 10^7 كلمة حينئذ _____ ثانية لكل حساب.

بنك الكلمات: 1، 1000، 10000، 100

٣ أيّ الممارسات سليمة لتخزين كلمات السر؟ اختر كل ما ينطبق.

☐ SHA-256 مع ملح واحد لكل المستخدمين ☐ فحص كلمات السر الجديدة مقابل القوائم المسرّبة

☐ Argon2id مع ملح فريد لكل مستخدم ☐ تشفير كلمات السر ليقرأها المديرون

٤ يستطيع وكيل تصيّد فوري أن ينقل رمزًا لمرة واحدة أُرسل برسالة نصية قبل أن تنتهي صلاحيته.

○ صح ○ خطأ

٥ طابق كل هجوم مع الدفاع الذي يوقفه مباشرة.

جداول قوس قزح المحسوبة مسبقًا	• • • •	تجزئة بطيئة كثيفة الذاكرة
هجوم قاموس بمعالج رسوميات على تسرّب	• • • •	مفاتيح أجهزة مرتبطة بالمصدر
حشو بيانات دخول من اختراقات أخرى	• • • •	ملح فريد
وكيل تصيّد فوري	• • • •	عامل ثانٍ

الإجابات، لعضو هيئة التدريس

التجزئة وكلمات السر والتحقق من الهوية

الأمن السيبراني، الجامعة، المحاضرة ٣

١ مفتاح أمان FIDO2

مفتاح FIDO2 لا يوقّع إلا لمصدر الموقع الحقيقي، أما رمز التطبيق أو إشعار الموافقة فتنقله الصفحة المزيّفة أو يوافق عليه مستخدم مخدوع.

٢ يجرّب برنامج كسر 10^9 تجزئة سريعة في الثانية. فإذا كلّف كل تخمين بـ Argon2id أكثر بـ 10^6 مرة، فلن ينجز إلا 1000 تخمين في الثانية. ويستغرق قاموس من 10^7 كلمة حينئذ 10000 ثانية لكل حساب.

$10^3 = 10^6 / 10^9$ تخمين في الثانية، و$10^3 / 10^7 = 10000$ ثانية لكل حساب، ويُضرب ذلك في عدد الحسابات بسبب الملح.

٣ Argon2id مع ملح فريد لكل مستخدم، فحص كلمات السر الجديدة مقابل القوائم المسرّبة

الملح المشترك والتجزئة السريعة يسمحان بكسر سريع، والتشفير القابل للعكس يعني أن تسرّب مفتاح واحد يكشف كل كلمات السر.

٤ صح

تساعد رموز الرسائل النصية ضد إعادة استعمال كلمات المرور، لكن صفحة دخول مزيّفة تستطيع أن تطلب الرمز وتستعمله فورًا.

٥ جداول قوس قزح المحسوبة مسبقًا — ملح فريد

هجوم قاموس بمعالج رسوميات على تسرّب — تجزئة بطيئة كثيفة الذاكرة

حشو بيانات دخول من اختراقات أخرى — عامل ثانٍ

وكيل تصيّد فوري — مفاتيح أجهزة مرتبطة بالمصدر

كل دفاع يجيب عن هجوم محدد، وينبغي أن يستطيع الطلاب تحديده.

لتفكّر فيه

كيف يمكن لطلابك أن يختبروا الفرق بين التجزئة السريعة والبطيئة بأمان دون بيانات مستخدمين حقيقيين؟